

AI cross-border requirements: a scannable checklist

Every guarantee an AI cross-border service owes, the SOC 2 criterion it sits under, and the evidence a reviewer will ask for — in tables.

How to use it: each row is a guarantee, the SOC 2 criterion it falls under, and the evidence

a reviewer will ask for. SOC 2 is a **procedural assessment of how an organisation operates**, reported by an independent CPA firm — not a certification of a product or a database. The full definition, and why AI transport widens its scope, is in The AI ladder, §7 "SOC 2: what AI transport puts in scope".

1. Data governance

GUARANTEE	SOC 2 CRITERION	EVIDENCE TO SHOW
Know what personal data exists and where it lives	Confidentiality C1.1	Data inventory per system; the country each store is in
Consent before processing, per jurisdiction	Privacy P2–P3	Jurisdiction resolved from location (not language); one consent event per grant, with the wording version
Collect only what the purpose needs	Privacy P3	Field list per form; free text treated as personal data
Retention limits enforced by a job , not only a policy	Confidentiality C1.2 · Privacy P4	The scheduled job, its period, its last successful run
Erasure reaches every copy — including AI stores	Privacy P4	A deletion request traced through database, files, vector index, agent memory, prompt logs, ad platforms
Data-subject access on request	Privacy P5	A lookup that finds a person's rows without exposing others
Subprocessors named, with where each processes	Privacy P6 · CC9.2	The published list; each provider's own report

2. Transport

GUARANTEE	SOC 2 CRITERION	EVIDENCE TO SHOW
Encryption in transit everywhere	CC6.7	HTTPS-only configuration; no plaintext endpoints
Field-level encryption, keys held apart from the data	CC6.1	The database holds ciphertext; the key lives elsewhere
Keys rotated, never passed around	CC6.1	Rotation record by fingerprint — never the value
Secrets never written to logs	CC6.1 · CC7.2	Request logging off where a secret or key crosses the wire
Every cross-border flow named and switchable	Privacy P6	An itemised disclosure per flow, and a way to suspend one flow without stopping the site
Where data lives is a setting of the deployment , not code	CC8.1	Per-instance configuration; a changed residency changes who is asked to consent

3. Horizontal scaling and availability

GUARANTEE	SOC 2 CRITERION	EVIDENCE TO SHOW
No single point of failure in the answer path	Availability A1.1	A second path that answers when the primary is down
Writes survive a component outage	Availability A1.2	Buffered writes replayed in order after recovery
Retries never double-charge or double-order	Processing Integrity PI1.3	Idempotency keys; payment replay guards
Capacity measured, not assumed	Availability A1.1	A load test, or recorded limits per provider and region
Failures detected and alerted	CC7.2	Logged reasons for every refusal; an alert that someone receives
Changes pass a test gate	CC8.1	The release gate; deploys tagged to a commit

4. AI-specific

GUARANTEE	EVIDENCE TO SHOW
The model provider does not train on your data	The provider's terms for the product and plan used
Inference runs where the data is allowed to go	Region per model; personal data never sent to a global endpoint
The agent cannot decide permissions	Permission checked in the endpoint; the agent acts only under a signed, capped, revocable mandate
Prompt, output and memory logs follow the same retention and erasure	A period per AI store, and erasure proven against each
Wrong answers are caught, escalated and corrected	A score threshold that refuses weak answers; a human escalation path with tiers
Model, prompt and adapter changes are controlled	Versioned, reviewed, gated like code

5. US integration-platform (ERP/CRM middleware) fees

Only MuleSoft's entry price and Boomi's pay-as-you-go are published by the vendors; every other figure is a third-party estimate. **Get a quote.**

PLATFORM	PUBLISHED / REPORTED PRICING	MODEL
MuleSoft (Salesforce)	From \$2,000/month, billed annually (official). 2026 packages priced by Mule flows and messages; legacy vCore plans reported at ~\$1,250–\$1,750 per vCore per month; premium connectors ~ \$10k–\$15k each per year (Automation Atlas , Integrate.io)	Quote above entry
Boomi	Pay-as-you-go \$99/month + \$0.05 per message (official); committed editions quote-only, reported \$50k–\$190k+/year , total cost often 2–3× licence (Automation Atlas)	Per message, or annual contract
Celigo	No list price; reported ~ \$1,000–\$1,500/month small, \$5,000+/month enterprise (~\$12.8k–\$73k/year by company size) (Vendr , Integrate.io)	Quote, by flows and endpoints

What the fee does not include: the controls in §1–§4. A middleware platform moves data; the consent, retention, erasure and residency evidence is still the organisation's to produce.

6. Retention and consent gaps that become penalties (US)

SYSTEM	WHAT TO CHECK	WHY IT MATTERS
Email / SMS marketing platform (e.g. Klaviyo)	Whether it offers a retention period per data type; how deletion treats suppression lists; where exports are kept	Old events keep powering segments and retargeting unless something purges them
CRM (e.g. Salesforce)	Deleted records stay in the Recycle Bin 15 days ; field history is kept 18–24 months (longer is an add-on); whether marketing data extensions carry a retention setting	Consent recorded in one cloud does not stop a send or sync in another unless it is enforced there too
Agent runtimes (e.g. Google ADK / Agent Engine)	Whether sessions and memory are reached by your erasure process	An erased customer's words can survive in agent memory
Google Ads / Merchant Center	Customer Match needs consented data; EEA traffic needs Consent Mode v2 (<code>ad_user_data</code> , <code>ad_personalization</code>); the Merchant loyalty member API takes unhashed email and phone; YouTube affiliate reporting must not be joined with personal or CRM data	Policy breaches lead to account suspension
Retargeting	Cross-context behavioural advertising is "sharing" under CCPA/CPRA: honour Global Privacy Control and "Do Not Sell or Share"	\$2,663 per violation; \$7,988 intentional or involving under-16s (2025 figures, CPPA), assessed per consumer; breach private actions \$107–\$799 per consumer . Sephora paid \$1.2M (2022)
Video pages	Ad pixels on pages that play video can trigger the Video Privacy Protection Act	Use a privacy-enhanced player and keep ad pixels off video pages without consent

7. The one-line summary per section

SECTION	IF YOU REMEMBER ONE THING
Governance	Erasure must reach AI stores, not only the database
Transport	Where data lives is a deployment setting, and it decides who must consent
Scaling	A second answer path and idempotent retries, or availability is a hope
AI-specific	The agent never decides what it may do
Middleware fees	The fee moves data; it does not produce the compliance evidence
Penalties	Retargeting without honouring opt-out is priced per consumer